

Interpretación de un incidente ejecutado mediante un agente de IA

Aplicación didáctica al módulo Incidentes de Ciberseguridad

Caso de actualidad: notificación de una brecha de datos personales a la AEPD (septiembre de 2026)

1. Descripción del incidente

La noticia describe la primera notificación recibida por la Agencia Española de Protección de Datos (AEPD) en la que una brecha de seguridad habría sido ejecutada, al menos en una parte sustancial del ataque, mediante un agente de inteligencia artificial. Según la información publicada, el agente inició una búsqueda de vulnerabilidades sobre recursos y archivos de carácter genérico y consiguió acceder a la organización mediante un inicio de sesión válido. Una vez dentro del entorno, continuó explorando de forma autónoma la aplicación, identificó posibles debilidades, accedió a información sensible —entre ella facturas— y llegó a modificar datos personales. La organización afectada no ha sido identificada públicamente y la AEPD continúa analizando el incidente, por lo que algunos elementos técnicos, como el vector inicial exacto, la procedencia de las credenciales, la vulnerabilidad explotada o el modelo concreto utilizado, no están confirmados. El aspecto diferencial del caso no reside tanto en la existencia de nuevas técnicas de ataque, sino en la capacidad de un agente para encadenar tareas de reconocimiento, acceso, exploración, explotación y adaptación sin que un operador humano tenga que tomar cada decisión intermedia. Esto incrementa la velocidad, la escala y la capacidad de adaptación del ataque y obliga a revisar cómo se previenen, detectan, investigan y contienen los incidentes de ciberseguridad.

Idea central: se trata de un incidente clásico en sus efectos, pero distinto en la forma y velocidad de ejecución. La IA agéntica automatiza y encadena técnicas ya conocidas, reduciendo el tiempo disponible para la defensa.

2. Cadena de ataque que puede inferirse

Fase	Qué ocurre	Estado de la información
Reconocimiento	Búsqueda inicial de archivos, recursos o posibles vulnerabilidades.	Descrito en la noticia.
Acceso	Inicio de sesión válido en la organización.	Descrito, pero sin confirmarse cómo se obtuvieron las credenciales.
Exploración interna	Búsqueda autónoma de vulnerabilidades en la aplicación.	Descrito en la noticia.
Explotación	Aprovechamiento de debilidades encontradas para ampliar el acceso.	Inferido a partir de la actividad descrita; detalle técnico no publicado.
Acceso a información	Consulta de facturas y otros datos.	Descrito en la noticia.
Impacto sobre datos	Modificación de datos personales.	Descrito en la noticia.

Detección y notificación	La organización detecta la brecha y la comunica a la AEPD.	Confirmado por la existencia de la notificación.
--------------------------	--	--

3. Relación con la asignatura Incidentes de Ciberseguridad

Unidad Didáctica 1. Planes de prevención y concienciación en ciberseguridad

- **Análisis de riesgos y principios generales:** El caso obliga a incorporar los ataques asistidos o ejecutados por agentes de IA dentro del análisis de riesgos. El riesgo no depende únicamente de que exista una vulnerabilidad, sino también de la capacidad del atacante para localizarla, probarla y explotarla con rapidez. La defensa en profundidad, el principio de mínimo privilegio, la segmentación, Zero Trust y una buena gestión de identidades reducen el impacto si una cuenta resulta comprometida.
- **Protección del puesto de trabajo y hardening:** El hardening de sistemas Windows y Linux, las políticas GPO, la eliminación de servicios innecesarios, la actualización continua, el control de aplicaciones y el uso de EDR aumentan la dificultad de movimiento y explotación. Herramientas como Sysmon o Wazuh permiten además registrar comportamientos que posteriormente podrán correlacionarse.
- **Formación y concienciación:** La concienciación debe evolucionar. Ya no basta con advertir sobre correos sospechosos: deben tratarse el robo y abuso de credenciales, tokens, sesiones, API keys, MFA fatigue y permisos excesivos. Un agente que obtiene una identidad válida puede operar a velocidad de máquina.
- **Auditorías internas:** Las auditorías basadas en ISO/IEC 27001, ENS, NIS2 o CIS Controls deben comprobar especialmente inventario de activos, gestión de vulnerabilidades, configuración segura, control de accesos, trazabilidad y monitorización. El caso demuestra que una vulnerabilidad no corregida puede ser localizada y explotada con mucha rapidez.

Unidad Didáctica 2. Detección y análisis de incidentes

- **Clasificación del incidente:** El incidente puede clasificarse inicialmente como acceso no autorizado mediante cuenta válida, exploración de aplicaciones, posible explotación de vulnerabilidades, acceso a información y alteración de datos personales. Afecta claramente a la confidencialidad y a la integridad; con la información publicada no puede afirmarse que afectara a la disponibilidad.
- **Monitorización y SIEM:** Un SIEM como Wazuh, ELK o Splunk debería correlacionar eventos que de forma aislada pueden parecer normales: un login correcto, cambio de IP o dispositivo, aumento de peticiones HTTP, múltiples errores 403/404/500, acceso a endpoints poco habituales, consultas masivas y modificaciones en base de datos.
- **IDS/IPS:** Suricata o Snort podrían detectar patrones de exploración, enumeración, escaneo o intentos de explotación. La utilidad aumenta cuando estas alertas se combinan con eventos de autenticación y actividad de aplicación.
- **Clasificación, valoración y seguimiento:** El analista debe diferenciar hechos confirmados, indicios e hipótesis. Por ejemplo, saber que existió un login válido no permite concluir por sí solo si hubo credenciales robadas, credential stuffing, secuestro de sesión o uso indebido de un token.
- **Gestión del caso:** Plataformas como TheHive permiten centralizar evidencias, tareas, indicadores y decisiones. MISP puede utilizarse si aparecen indicadores de compromiso que deban compartirse con otros equipos u organismos.

Unidad Didáctica 3. Investigación forense de incidentes

- **Recopilación de evidencias:** Sería necesario preservar logs de autenticación, servidor web, WAF, EDR, firewall, proxy, IAM, aplicación, APIs, base de datos y servicios cloud. Cada evidencia debe conservarse con su hash y dentro de una cadena de custodia documentada.
- **Reconstrucción temporal:** Una tarea esencial sería construir una línea temporal desde el primer contacto hasta la contención: reconocimiento, autenticación, enumeración, descubrimiento de vulnerabilidades, explotación, acceso a facturas, modificación de datos, detección y respuesta.
- **Análisis forense:** Autopsy o FTK Imager permitirían estudiar almacenamiento; Volatility o herramientas equivalentes, analizar memoria cuando proceda. También sería necesario revisar tokens, sesiones activas, procesos, conexiones de red y artefactos de la aplicación.
- **Atribución técnica:** Una cuestión especialmente interesante es determinar qué evidencias permiten afirmar que las acciones fueron ejecutadas por un agente de IA. El volumen de peticiones o la rapidez no son prueba suficiente por sí solos. Deben buscarse trazas técnicas que relacionen sesiones, herramientas, infraestructura y secuencias de acciones.
- **Contención inicial:** Las primeras medidas podrían incluir revocar sesiones y tokens, bloquear o resetear cuentas afectadas, rotar credenciales y API keys, aislar sistemas, bloquear indicadores y proteger los activos donde se han encontrado las vulnerabilidades.

Unidad Didáctica 4. Respuesta y mitigación

- **Procedimientos y playbooks:** El incidente evidencia la necesidad de disponer de runbooks y playbooks previamente definidos. Cuando el atacante actúa a velocidad de máquina, improvisar cada decisión durante el incidente aumenta el tiempo de respuesta.
- **Automatización defensiva:** La automatización ofensiva favorece la automatización defensiva. Un SOAR puede recibir una alerta del SIEM y ejecutar acciones de primera respuesta: revocar tokens, deshabilitar temporalmente una cuenta, bloquear una IP, aislar un endpoint o abrir automáticamente un caso para el SOC.
- **Ciberresiliencia:** Zero Trust, segmentación, mínimo privilegio y separación entre sistemas reducen el radio de impacto. Aunque una identidad sea comprometida, el atacante no debería poder acceder indiscriminadamente a todos los recursos.
- **Recuperación:** Tras contener y erradicar la amenaza deben restaurarse sistemas y datos desde estados confiables, corregirse vulnerabilidades y comprobar que las credenciales y mecanismos de acceso han sido renovados.
- **Lecciones aprendidas:** El post-mortem debe identificar causa raíz, controles que fallaron, controles que funcionaron, MTDD, MTTR y cambios necesarios. El objetivo no es únicamente cerrar el incidente, sino reducir la probabilidad y el impacto de uno similar.

Unidad Didáctica 5. Documentación y notificación de incidentes

- **Brecha de datos personales:** El acceso y la modificación no autorizados de datos personales convierten el caso en una brecha de datos personales. Esto activa obligaciones específicas de evaluación, documentación y, cuando corresponda, notificación.
- **Notificación interna:** El flujo debería escalar desde el equipo técnico o SOC hacia responsable de seguridad, DPO, dirección y asesoría jurídica, manteniendo un registro cronológico de decisiones y acciones.
- **Autoridades competentes:** La existencia de la notificación a la AEPD convierte el caso en un ejemplo directo del contenido 5.3. Dependiendo de la organización y sector, podrían existir además obligaciones frente a otros organismos bajo NIS2, ENS u otra normativa aplicable.

- **Afectados:** Debe evaluarse el riesgo para los derechos y libertades de las personas y determinar si procede la comunicación directa a los afectados, explicando de forma clara la naturaleza de la brecha, sus posibles consecuencias y las medidas adoptadas.
- **Comunicación de crisis:** La comunicación externa debe ser coordinada. Debe evitar especulaciones y la publicación de detalles técnicos que faciliten nuevos ataques, diferenciando siempre datos confirmados de aspectos todavía bajo investigación.

Unidad Didáctica 6. Proyecto práctico final

- **Escenario integrador:** El caso puede transformarse en un proyecto final: una empresa ficticia dispone de servidor web, aplicación, API y base de datos con clientes y facturas. Un agente obtiene acceso y comienza a explorar automáticamente la aplicación.
- **Fuentes de evidencia:** El alumnado puede recibir progresivamente auth.log, access.log, alertas de Wazuh, alertas de Suricata, eventos Windows/Linux, registros de base de datos y capturas de tráfico.
- **Trabajo del alumnado:** Los estudiantes deben detectar el incidente, clasificarlo, formular hipótesis, preservar evidencias, reconstruir la cronología, contener, proponer medidas de recuperación, valorar las obligaciones de notificación y elaborar un informe técnico y ejecutivo.
- **Competencias integradas:** La práctica combina prevención, monitorización, investigación forense, respuesta, documentación, normativa y comunicación, reproduciendo de forma realista el trabajo de un equipo de respuesta a incidentes.

4. Ejemplo de correlación que debería detectar un SIEM

Secuencia de eventos: login válido → origen o dispositivo anómalo → incremento de peticiones → exploración de múltiples endpoints → errores HTTP repetidos → acceso a información sensible → modificación de datos.

Interpretación: ninguno de esos eventos tiene por qué ser concluyente de forma aislada. La detección eficaz surge de la correlación temporal y contextual de múltiples señales.

5. Línea temporal de investigación propuesta

1. T0 – Primer contacto o inicio de la actividad anómala.
2. T1 – Reconocimiento y enumeración.
3. T2 – Inicio de sesión válido.
4. T3 – Exploración interna de la aplicación.
5. T4 – Descubrimiento de una vulnerabilidad.
6. T5 – Explotación o abuso de la funcionalidad.
7. T6 – Acceso a facturas y otra información.
8. T7 – Modificación de datos personales.
9. T8 – Detección del comportamiento anómalo.
10. T9 – Contención, recuperación y notificación.

6. Conclusión didáctica

Este caso permite explicar al alumnado que la IA agéntica no invalida el ciclo tradicional de respuesta a incidentes, sino que aumenta la necesidad de aplicarlo con rapidez, trazabilidad y automatización. Los principios siguen siendo los mismos: prevenir, detectar, analizar, contener, erradicar, recuperar, notificar y

aprender. Lo que cambia es la velocidad con la que el atacante puede realizar reconocimiento, probar alternativas, interpretar resultados y cambiar de estrategia. Por ello, la defensa debe combinar controles preventivos sólidos, observabilidad, correlación en SIEM, respuesta automatizada, capacidades forenses y procedimientos jurídicos y de comunicación bien definidos.

Frase para trabajar en clase: “La IA agéntica no sustituye las técnicas tradicionales de ataque: las encadena, automatiza y acelera. Por eso tampoco sustituye la respuesta a incidentes, pero obliga a automatizar parte de la detección y de la contención.”

7. Posibles preguntas para el alumnado

- ¿Qué datos permiten afirmar que existe un incidente de seguridad y cuáles siguen siendo únicamente hipótesis?
- ¿Qué fuentes de log solicitarías primero y por qué?
- ¿Qué regla de correlación crearías en Wazuh o en otro SIEM para detectar una secuencia similar?
- ¿Qué medidas de contención ejecutarías inmediatamente después de detectar una cuenta válida utilizada de forma anómala?
- ¿Cómo distinguirías una acción automatizada convencional de una actuación atribuible a un agente de IA?
- ¿Qué información debería contener el informe técnico del incidente y qué información trasladarías a dirección?
- ¿Qué obligaciones de notificación pueden activarse si se han accedido o modificado datos personales?